Take Over Workforce
Accounts by Defeating
Multi-Factor Authentication

Capture live
authentication sessions to
obtain valid enterprise
tokens and operate
as the employee across
every federated
application

Workforce Sign-In Portal

CWE-294: Authentication
Bypass by
Capture-replay

CWE-308: Use of Single-
factor
Authentication

Session and Token Issuance
Service

CWE-384: Session Fixation

CWE-613: Insufficient
Session Expiration

CWE-522: Insufficiently
Protected
Credentials

CWE-294: Authentication
Bypass by
Capture-replay

Enroll an attacker-
controlled authenticator
on a targeted employee
account to hold
access independent of the
original device

Authenticator Enrollment
and Delivery
Channel

CWE-306: Missing
Authentication for
Critical Function

CWE-640: Weak Password
Recovery
Mechanism for Forgotten
Password

CWE-330: Use of
Insufficiently Random
Values

CWE-319: Cleartext
Transmission of
Sensitive Information

CWE-290: Authentication
Bypass by
Spoofing

Impersonate Any
Enterprise User by Forging
Federated Authentication
Assertions

Steal the federation
signing key to mint
assertions for any user of
any connected
application without
touching a password

Token Signing Key Custody

CWE-522: Insufficiently
Protected
Credentials

CWE-327: Use of a Broken
or Risky
Cryptographic Algorithm

CWE-306: Missing
Authentication for
Critical Function

CWE-732: Incorrect
Permission Assignment
for Critical Resource

Federation Service

CWE-290: Authentication
Bypass by
Spoofing

CWE-15: External Control
of System or
Configuration Setting

Relying Party Assertion
Validation

CWE-347: Improper
Verification of
Cryptographic Signature

CWE-91: XML Injection
(aka Blind XPath
Injection)

Register an attacker-
controlled identity
provider in the tenant so
that account
linking survives every
password reset

Identity Provider Trust
Configuration

CWE-285: Improper
Authorization

CWE-302: Authentication
Bypass by
Assumed-Immutable Data

CWE-346: Origin Validation
Error

CWE-295: Improper
Certificate Validation

Seize Enterprise-Wide
Administrative Control
of the Identity Directory

Convert a standard
directory account into a
domain administrator to
reach every system
the directory authenticates

Domain Controller

CWE-309: Use of Password
System for
Primary Authentication

CWE-836: Use of Password
Hash Instead of
Password for
Authentication

CWE-285: Improper
Authorization

CWE-269: Improper
Privilege Management

Enterprise Certificate
Authority

CWE-732: Incorrect
Permission Assignment
for Critical Resource

CWE-290: Authentication
Bypass by
Spoofing

Sell verified administrative
access to the
enterprise directory to
ransomware and
espionage operators

Cloud Directory Tenant

CWE-269: Improper
Privilege Management

CWE-1220: Insufficient
Granularity of
Access Control

CWE-285: Improper
Authorization

Hybrid Directory
Synchronization Connector

CWE-250: Execution with
Unnecessary
Privileges

CWE-522: Insufficiently
Protected
Credentials

Encrypt Enterprise
Operations for Ransom
Through Directory
Compromise

Use directory-wide
administrative control to
encrypt every domain-
joined system at once
and extort payment for
restoration

Domain Controller

CWE-285: Improper
Authorization

CWE-250: Execution with
Unnecessary
Privileges

Privileged Access Tier

CWE-923: Improper
Restriction of
Communication Channel to
Intended
Endpoints

CWE-272: Least Privilege
Violation

Directory Backup and
Forest Recovery Store

CWE-732: Incorrect
Permission Assignment
for Critical Resource

CWE-312: Cleartext
Storage of Sensitive
Information

CWE-306: Missing
Authentication for
Critical Function

Exfiltrate Directory and
Customer Identity
Records from Identity
Platforms

Extract the complete user
directory with
attributes and group
memberships to enable
targeted intrusion and
resale

Directory Data Store

CWE-90: Improper
Neutralization of
Special Elements used in
an LDAP Query
('LDAP Injection')

CWE-285: Improper
Authorization

Identity Management API

CWE-302: Authentication
Bypass by
Assumed-Immutable Data

CWE-770: Allocation of
Resources Without
Limits or Throttling

Harvest stored credential
material and
recovery secrets from
identity data stores
for offline cracking and

reuse

Credential and Secret
Storage

CWE-312: Cleartext
Storage of Sensitive
Information

CWE-916: Use of Password
Hash With
Insufficient Computational
Effort

CWE-522: Insufficiently
Protected
Credentials

Identity Platform
Diagnostic Export

CWE-532: Insertion of
Sensitive
Information into Log File

CWE-359: Exposure of
Private Personal
Information to an
Unauthorized Actor

Defraud Customers
Through Mass Account
Takeover of Consumer
Identity Platforms

Replay breached
credential lists against
consumer sign-in
endpoints at scale to seize
accounts holding stored
value and payment
methods

Consumer Sign-In Endpoint

CWE-307: Improper
Restriction of
Excessive Authentication
Attempts

CWE-521: Weak Password
Requirements

CWE-601: URL Redirection
to Untrusted
Site ('Open Redirect')

CWE-290: Authentication
Bypass by
Spoofing

CWE-302: Authentication
Bypass by
Assumed-Immutable Data

Take over consumer
accounts through self-
service recovery without
ever holding the
original credential

Account Recovery Flow

CWE-640: Weak Password
Recovery
Mechanism for Forgotten
Password

CWE-306: Missing
Authentication for
Critical Function

Social Login and External
Identity Broker

CWE-346: Origin Validation
Error

CWE-290: Authentication
Bypass by
Spoofing

Extract Data From
Connected Platforms by
Abusing Delegated OAuth
Authorization

Obtain a durable consent
grant from a user
or administrator so that
data access
continues after every
password and session
reset

OAuth Authorization Server

CWE-285: Improper
Authorization

CWE-267: Privilege
Defined With Unsafe
Actions

CWE-613: Insufficient
Session Expiration

Application Registration
and Consent Catalog

CWE-346: Origin Validation
Error

CWE-1220: Insufficient
Granularity of
Access Control

Steal refresh tokens held
by an integration
vendor and query every
tenant that
authorized it

Integration Vendor Token
Store

CWE-522: Insufficiently
Protected
Credentials

CWE-294: Authentication
Bypass by
Capture-replay

Connected Platform
Integration API

CWE-302: Authentication
Bypass by
Assumed-Immutable Data

CWE-770: Allocation of
Resources Without
Limits or Throttling

Compromise Identity
Platform Suppliers to
Reach Every Downstream
Tenant

Compromise an identity
platform supplier to
reach the authentication
of every customer
tenant through one trusted
channel

Identity Platform Vendor
Software and Update
Channel

CWE-494: Download of
Code Without
Integrity Check

CWE-347: Improper
Verification of
Cryptographic Signature

CWE-829: Inclusion of
Functionality from
Untrusted Control Sphere

CWE-506: Embedded
Malicious Code

Managed Service Provider
Delegated
Administration

CWE-269: Improper
Privilege Management

CWE-285: Improper
Authorization

Vendor Support and
Diagnostic Channel

CWE-532: Insertion of
Sensitive
Information into Log File

CWE-522: Insufficiently
Protected
Credentials

Hijack Machine and
Workload Identities to
Reach Production Data and
Compute

Recover long-lived service
credentials from
code, pipelines and
configuration to
authenticate to production
data as a trusted
workload

Secrets Manager and
Credential Vault

CWE-522: Insufficiently
Protected
Credentials

CWE-285: Improper
Authorization

CWE-1220: Insufficient
Granularity of
Access Control

CWE-613: Insufficient
Session Expiration

Build Pipeline and Source
Repository
Identity

CWE-798: Use of Hard-
coded Credentials

CWE-250: Execution with
Unnecessary
Privileges

CWE-312: Cleartext
Storage of Sensitive
Information

Assume over-scoped
workload roles to run
attacker compute and
reach data stores no
human account could open

Workload Identity
Federation

CWE-346: Origin Validation
Error

CWE-295: Improper
Certificate Validation

Container and Service
Mesh Identity

CWE-250: Execution with
Unnecessary
Privileges

CWE-306: Missing
Authentication for
Critical Function

CWE-295: Improper
Certificate Validation

Abuse Insider Identity
Administration to
Create Covert Standing
Access

Grant covert entitlements
to attacker-
controlled accounts and
clear them through
the reviewer's own
authority

Identity Governance and
Access Certification

CWE-269: Improper
Privilege Management

CWE-1220: Insufficient
Granularity of
Access Control

CWE-285: Improper
Authorization

CWE-267: Privilege
Defined With Unsafe
Actions

Privileged Role Assignment

CWE-276: Incorrect
Default Permissions

CWE-613: Insufficient
Session Expiration

Retain access after
departure through
accounts and entitlements
the leaver process

never removes

Joiner-Mover-Leaver
Provisioning Workflow

CWE-613: Insufficient
Session Expiration

CWE-309: Use of Password
System for
Primary Authentication

Break-Glass Emergency
Account

CWE-798: Use of Hard-
coded Credentials

CWE-306: Missing
Authentication for
Critical Function

Erase Identity Audit
Evidence to Defeat
Investigation and
Compliance Attestation

Destroy and forge identity
audit records so
that the intrusion cannot
be reconstructed
or attested to regulators

Identity Audit Log Pipeline
and Detection
Configuration

CWE-117: Improper Output
Neutralization
for Logs

CWE-732: Incorrect
Permission Assignment
for Critical Resource

CWE-306: Missing
Authentication for
Critical Function

CWE-15: External Control
of System or
Configuration Setting

Sign-In and Administrative
Event Store

CWE-269: Improper
Privilege Management

CWE-732: Incorrect
Permission Assignment
for Critical Resource

Deny Authentication
Services to Halt Every
Dependent Business
Application

Exhaust authentication
service capacity so
that no user can sign in to
any dependent
application

Authentication Endpoint
and Lockout Policy

CWE-770: Allocation of
Resources Without
Limits or Throttling

CWE-307: Improper
Restriction of
Excessive Authentication
Attempts

CWE-306: Missing
Authentication for
Critical Function

Destroy directory objects
and federation
configuration so that
access cannot be
restored from the platform
itself

Directory Object Lifecycle

CWE-269: Improper
Privilege Management

CWE-732: Incorrect
Permission Assignment
for Critical Resource

Federation Trust
Configuration

CWE-15: External Control
of System or
Configuration Setting

CWE-353: Missing Support
for Integrity
Check

Gain Unauthorized Physical
Access by
Subverting Converged
Badge and Credential
Issuance

Obtain a working physical
credential through
the identity platform's own
badge issuance
path to enter restricted
facilities

Physical Access Control
System

CWE-294: Authentication
Bypass by
Capture-replay

CWE-290: Authentication
Bypass by
Spoofing

CWE-285: Improper
Authorization

CWE-1220: Insufficient
Granularity of
Access Control

CWE-306: Missing
Authentication for
Critical Function

CWE-345: Insufficient
Verification of
Data Authenticity

Identity to Physical Access
Provisioning
Bridge

CWE-353: Missing Support
for Integrity
Check

Defeat Identity Proofing
and Help Desk
Verification With AI-
Generated Personas

Pass identity proofing and
help desk
verification with synthetic
personas to
obtain a legitimate
credential for a
fabricated identity

Remote Identity Proofing
and Biometric
Capture

CWE-345: Insufficient
Verification of
Data Authenticity

CWE-290: Authentication
Bypass by
Spoofing

CWE-346: Origin Validation
Error

CWE-353: Missing Support
for Integrity
Check

Help Desk and IT Support

CWE-287: Improper
Authentication

CWE-640: Weak Password
Recovery
Mechanism for Forgotten
Password

CWE-306: Missing
Authentication for
Critical Function

Hijack AI Agent Delegated
Authority to Act
Across Enterprise Systems

Redirect an autonomous
agent's delegated
authority through injected
content to act

against enterprise systems
under a trusted
identity

AI Agent Identity and
Delegation Chain

CWE-441: Unintended
Proxy or
Intermediary ('Confused
Deputy')

CWE-269: Improper
Privilege Management

Agent Tool and Connector
Authorization

CWE-285: Improper
Authorization

CWE-267: Privilege
Defined With Unsafe
Actions

CWE-1427: Improper
Neutralization of
Input Used for LLM
Prompting

Agent Credential and
Context Store

CWE-522: Insufficiently
Protected
Credentials

CWE-312: Cleartext
Storage of Sensitive
Information

CWE-798: Use of Hard-
coded Credentials

CWE-345: Insufficient
Verification of
Data Authenticity

Sell Customer Identity and
Behavioral Data
Beyond the Scope of
Consent

Monetize authentication
telemetry and
identity attributes beyond
the consented
purpose for advertising
and data broker
revenue

Consent and Preference
Store

CWE-359: Exposure of
Private Personal
Information to an
Unauthorized Actor

CWE-285: Improper
Authorization

CWE-345: Insufficient
Verification of
Data Authenticity

Authentication Telemetry
and Device
Fingerprinting

CWE-359: Exposure of
Private Personal
Information to an
Unauthorized Actor

Partner Data Sharing
Interface

CWE-1220: Insufficient
Granularity of
Access Control

CWE-302: Authentication
Bypass by
Assumed-Immutable Data

CWE-732: Incorrect
Permission Assignment
for Critical Resource